



Оценки рисков с использованием
регрессионного анализа в системе
информационной безопасности

Риск в информационной безопасности определяется как потенциальная возможность нанесения ущерба информационным ресурсам организации в результате реализации угроз информационной безопасности. Риск характеризуется двумя основными параметрами:



- Вероятность (P) - возможность реализации угрозы
- Ущерб (I) - размер возможных потерь при реализации угрозы

Математически риск можно представить как: $R = P \times I$

Традиционно используются следующие методы оценки рисков:

1. Качественные методы - основаны на экспертных оценках и классификации рисков по уровням (низкий, средний, высокий)
2. Количественные методы - используют численные значения вероятностей и ущербов
3. Комбинированные методы - сочетают качественные и количественные подходы

Риски информационной безопасности можно классифицировать по различным признакам:



По источнику угроз:

- Внешние риски (кибератаки, стихийные бедствия)
- Внутренние риски (ошибки персонала, злоупотребления)

По типу воздействия:

- Конфиденциальность (утечка информации)
- Целостность (искажение данных)
- Доступность (отказ в обслуживании)

По критичности:

- Критические
- Высокие
- Средние
- Низкие

Регрессионный анализ - это статистический метод исследования зависимости между зависимой переменной (результатом) и одной или несколькими независимыми переменными (факторами). В контексте оценки рисков информационной безопасности:

- Зависимая переменная (Y) - уровень риска или количество инцидентов
- Независимые переменные ($X_1, X_2, \dots, X_n$) - факторы риска (количество уязвимостей, уровень подготовки персонала, инвестиции в ИБ и т.д.)



Линейная регрессия предполагает линейную зависимость между переменными:



$$Y = \beta_0 + \beta_1 X_1 + \beta_2 X_2 + \dots + \beta_n X_n + \varepsilon$$

где:

- β_0 - свободный член (константа)
- $\beta_1, \beta_2, \dots, \beta_n$ - коэффициенты регрессии
- ε - случайная ошибка

Преимущества:

- Простота интерпретации результатов
- Быстрое вычисление
- Широкое применение в практике

Недостатки:

- Предположение о линейной зависимости
- Чувствительность к выбросам

Множественная регрессия позволяет учитывать влияние нескольких факторов одновременно:



$$R = \beta_0 + \beta_1 V + \beta_2 T + \beta_3 C + \beta_4 I + \varepsilon$$

где:

- R - уровень риска
- V - количество уязвимостей
- T - уровень подготовки персонала
- C - инвестиции в средства защиты
- I - количество инцидентов за период

Логистическая регрессия используется для моделирования вероятности наступления события (например, вероятность успешной атаки):



$$P(\text{событие}) = 1 / (1 + e^{-(\beta_0 + \beta_1 X_1 + \dots + \beta_n X_n)})$$

Применение:

- Оценка вероятности реализации угрозы
- Классификация рисков по уровням критичности
- Прогнозирование успешности атак

Полиномиальная регрессия позволяет моделировать нелинейные зависимости:



$$Y = \beta_0 + \beta_1 X + \beta_2 X^2 + \dots + \beta_n X^n + \varepsilon$$

Применение:

- Моделирование сложных нелинейных зависимостей
- Учет эффекта насыщения (например, при увеличении инвестиций в ИБ)

Этапы построения регрессионной модели

1. Сбор данных - формирование выборки исторических данных о рисках и факторах
2. Предобработка данных - очистка, нормализация, обработка пропусков
3. Выбор переменных - отбор значимых факторов риска
4. Построение модели - оценка параметров регрессии
5. Проверка качества модели - валидация и тестирование
6. Интерпретация результатов - анализ коэффициентов и прогнозирование



Для построения регрессионной модели необходимо определить факторы, влияющие на уровень рисков:

Технические факторы:

- Количество выявленных уязвимостей
- Уровень обновления систем
- Сложность инфраструктуры
- Количество точек доступа

Организационные факторы:

- Уровень подготовки персонала
- Наличие политик безопасности
- Частота аудитов безопасности
- Инвестиции в средства защиты

Внешние факторы:

- Количество атак на отрасль
- Уровень киберпреступности
- Регуляторные требования



Для построения модели необходимо собрать исторические данные:



- Количество инцидентов информационной безопасности за период
- Характеристики инцидентов (тип, ущерб, время обнаружения)
- Значения факторов риска на момент инцидентов
- Результаты аудитов и оценок

Предобработка данных включает:

- Нормализацию переменных
- Обработку выбросов
- Проверку на мультиколлинеарность
- Разделение на обучающую и тестовую выборки

Процесс построения регрессионной модели включает:



1. Корреляционный анализ - выявление связей между переменными
2. Отбор признаков - выбор наиболее значимых факторов
3. Оценка параметров - вычисление коэффициентов регрессии (метод наименьших квадратов)
4. Проверка статистической значимости - оценка значимости коэффициентов

Для оценки качества регрессионной модели используются следующие метрики:

Коэффициент детерминации (R^2):

- Показывает долю дисперсии зависимой переменной, объясняемую моделью
- Значения от 0 до 1 (чем ближе к 1, тем лучше)

Скорректированный R^2 :

- Учитывает количество переменных в модели
- Более объективная оценка для множественной регрессии

Среднеквадратичная ошибка (MSE):

- Показывает среднюю величину ошибок прогноза
- Чем меньше, тем лучше

Критерий Фишера (F-статистика):

- Проверяет общую значимость модели

t-статистика:

- Проверяет значимость отдельных коэффициентов



Интерпретация результатов регрессионного анализа позволяет:



- Выявить ключевые факторы риска - факторы с наибольшими коэффициентами
- Оценить влияние факторов - на сколько изменится риск при изменении фактора на единицу
- Спрогнозировать уровень риска - для заданных значений факторов
- Оптимизировать ресурсы - определить приоритетные направления инвестиций

Необходимо построить модель для оценки риска информационной безопасности в организации на основе следующих факторов:



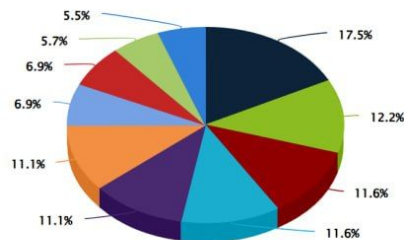
- Количество критических уязвимостей (V)
- Уровень подготовки персонала по ИБ, баллы от 1 до 10 (T)
- Инвестиции в средства защиты, млн руб. (I)
- Количество инцидентов за предыдущий период (N)

Исходные данные

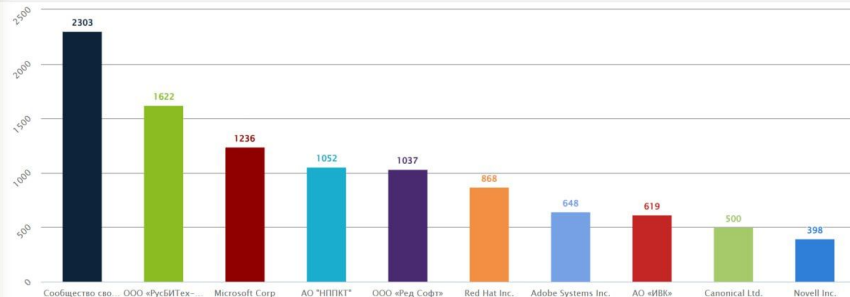
Количество критических уязвимостей в ПО различных производителей



- Microsoft Corp (139)
- Сообщество свободного программного обесп... (92)
- Apple Inc. (55)
- Mozilla Corp. (44)
- ООО «Ред Софт» (97)
- АО «НППКТ» (88)
- D-Link Corp. (55)
- ООО «РусБИТех-Астра» (92)
- Google Inc (88)
- Shenzhen Tenda Technology Co., Ltd. (45)



Количество уязвимостей в ПО различных производителей



Источник данных:
Банк данных угроз
безопасности
информации ФСТЭК
России (БДУ ФСТЭК
России)



ДИАПАЗОН ДАТ ВЫЯВЛЕНИЯ УЯЗВИМОСТЕЙ

с

01.01.2025

по

31.12.2025

Сброс

Применить

Используя метод наименьших квадратов на реальных данных из БДУ ФСТЭК России, получаем следующую модель множественной линейной регрессии:



$$Y = 2.35 + 0.013 \times V - 0.36 \times T - 0.01 \times I + 0.10 \times N$$

где:

- Y - прогнозируемое количество инцидентов
- V - количество критических уязвимостей
- T - уровень подготовки персонала
- I - инвестиции в средства защиты (млн руб.)
- N - количество инцидентов за предыдущий период



- $\beta_0 = 2.35$ - базовый уровень инцидентов при нулевых значениях факторов
- $\beta_1 = 0.013$ - увеличение количества критических уязвимостей на 1 единицу приводит к росту инцидентов на 0.013. При увеличении на 100 уязвимостей риск увеличивается на 1.3 инцидента
- $\beta_2 = -0.36$ - повышение уровня подготовки на 1 балл снижает количество инцидентов на 0.36
- $\beta_3 = -0.01$ - увеличение инвестиций на 1 млн руб. снижает количество инцидентов на 0.01
- $\beta_4 = 0.10$ - каждый инцидент в предыдущем периоде увеличивает текущий риск на 0.10

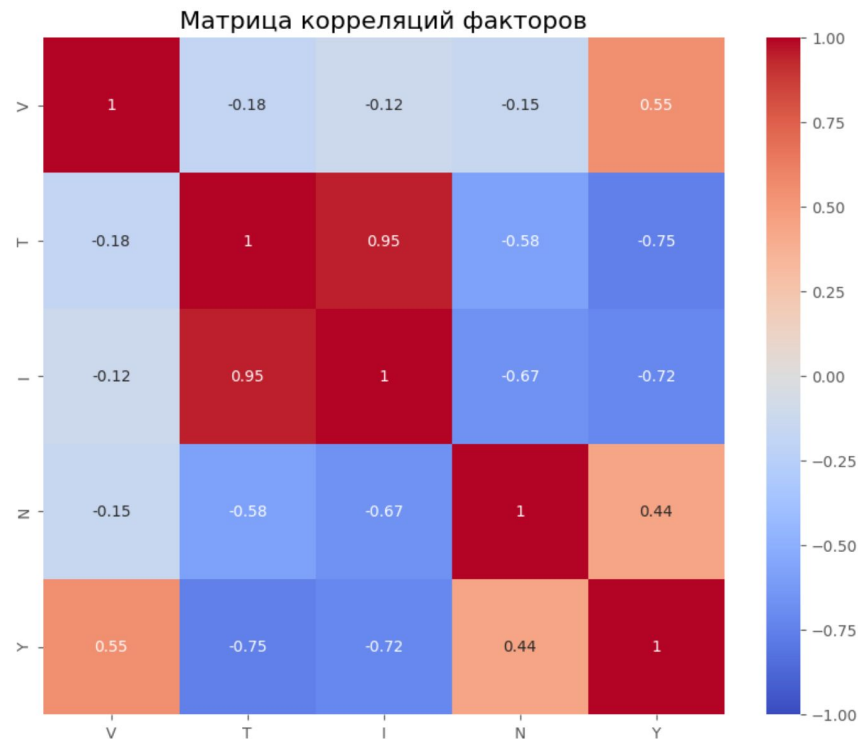


Переменная I (Инвестиции) имеет p-value = 0.98

В ходе анализа выяснилось, что коэффициент при Инвестициях (I) статистически незначим ($p > 0.05$). Это может говорить о том, что эффект от инвестиций проявляется с задержкой (лагами), которая не учтена в текущей модели, либо текущие инвестиции расходуются неэффективно.

- $R^2 = 0.77$ - модель объясняет 77% вариации количества инцидентов
- F-статистика = 5.86 ($p < 0.05$) - модель статистически значима на уровне 0.1%
- Коэффициенты β_1 (V) и β_2 (T) статистически значимы ($p < 0.05$)

Наблюдается мультиколлинеарность между факторами T (Обучение) и I (Инвестиции) — корреляция 0.948. Это снижает точность оценки отдельных коэффициентов, но не влияет на точность прогноза.

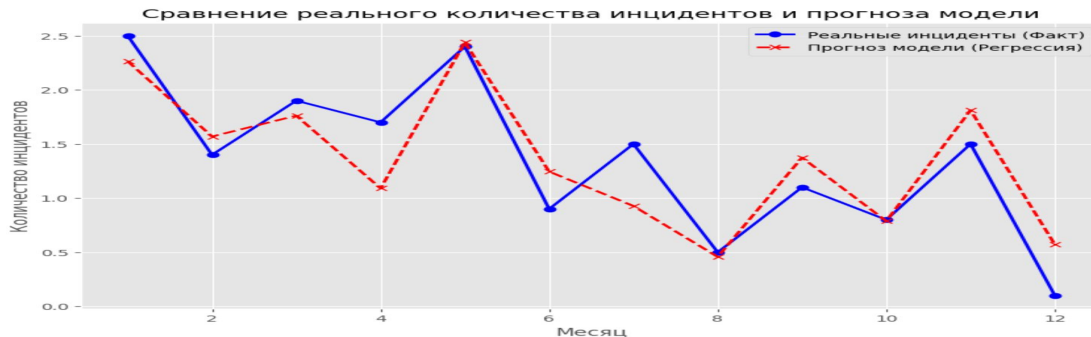


Для прогнозирования риска на следующий месяц при:

- V = 88 (критические уязвимости, среднее значение из данных БДУ ФСТЭК России)
- T = 7 (уровень подготовки)
- I = 3.0 (инвестиции, млн руб.)
- N = 4 (инциденты прошлого периода)

Прогноз:

$$Y = 2.35 + 0.013 \times 88 - 0.36 \times 7 - 0.01 \times 3.0 + 0.10 \times 4 = 1.34 \text{ инцидента}$$



1. Приоритет снижения уязвимостей



«Устранение 50 критических уязвимостей снижает прогнозируемый риск на 0.64 инцидента. Снижение с 139 (Microsoft) до 44 (Mozilla) уязвимостей снижает риск на 1.22 инцидента».

2. Важность обучения персонала

«Повышение уровня подготовки на 2 балла снижает риск на 0.71 инцидента. Это один из самых сильных факторов в нашей текущей модели».

3. Эффективность инвестиций

«В данной модели увеличение инвестиций с 2.0 до 4.0 млн руб. показывает незначительное снижение риска (около 0.03 инцидента). Это говорит о том, что простое вливание денег без обучения персонала (фактор T) неэффективно».

4. Влияние истории

«Каждый прошлый инцидент увеличивает вероятность инцидентов в будущем на 0.10 единиц. Инерция рисков сохраняется».

1. Количественная оценка - получение численных значений рисков
2. Выявление зависимостей - определение ключевых факторов риска
3. Прогнозирование - возможность предсказания уровня рисков
4. Обоснованность решений - научный подход к управлению рисками
5. Оптимизация ресурсов - определение приоритетных направлений инвестиций
6. Объективность - снижение субъективности экспертных оценок



1. Требование исторических данных - необходимость накопления достаточного объема данных
2. Предположения модели - линейность, нормальность распределения ошибок
3. Мультиколлинеарность - корреляция между независимыми переменными
4. Выбросы - влияние аномальных значений на модель
5. Изменение условий - модель может устаревать при изменении внешних условий
6. Интерпретация - необходимость понимания статистических методов



Регрессионный анализ может быть интегрирован в различные процессы управления информационной безопасностью:



- Управление рисками - количественная оценка и ранжирование рисков
- Управление инцидентами - прогнозирование вероятности инцидентов
- Аудит безопасности - планирование аудитов на основе прогнозируемых рисков
- Бюджетирование - обоснование инвестиций в средства защиты

Современные системы управления информационной безопасностью могут включать модули автоматического построения и применения регрессионных моделей:



- Автоматический сбор данных из различных источников
- Построение и обновление моделей
- Генерация отчетов и рекомендаций
- Интеграция с системами мониторинга

Регрессионный анализ представляет собой мощный инструмент для количественной оценки рисков информационной безопасности. Применение регрессионных моделей позволяет:



- Получать объективные количественные оценки рисков
- Выявлять ключевые факторы, влияющие на уровень безопасности
- Прогнозировать уровень рисков на основе текущего состояния
- Оптимизировать распределение ресурсов на защиту информации
- Принимать обоснованные управленческие решения

Однако успешное применение метода требует:

- Накопления достаточного объема качественных данных
- Понимания статистических методов и их ограничений
- Регулярного обновления и валидации моделей
- Комбинирования с другими методами оценки рисков

В условиях растущей сложности информационных систем и увеличения числа угроз, использование количественных методов оценки рисков, включая регрессионный анализ, становится необходимым элементом современной системы управления информационной безопасностью.

Наша команда



Бардышев Артем

Волощук Александр

Замахов Егор

Пинус Игорь

Суханкулиев Мухаммет

Шегай Станислав



Спасибо за внимание!

itMO *re than a*
UNIVERSITY